

Vishing, Smishing & AI-Powered Attacks

Vishing – Voice Social Engineering

Phone-based attacks work because people are more polite on the phone than with email.

Classic plays:

- "Bank security" wants to confirm a transaction (then steal OTP)

- "IT support" needs your password for a "fix"

- Fake caller ID (spoofed numbers, "your bank" with the real number)

Defense: if a caller claims urgency about YOUR account – hang up and call the number on the BACK of your card / official site yourself.

Smishing – SMS Social Engineering

Texts:

- "Your package is undeliverable, click to track" → credential harvest

- "Your account is suspended, verify here"

- QR-code quishing: a printed/stuck QR code on parking meters & machines – scan = phish

The QR phish is spicy: it's physical, unverifiable, and phones often bypass URL filters. Research "quishing" – corporate 2FA pages are the target.

AI: The New Social Engineering Weapon

Generative AI changed the game:

Before	With AI
Phishing with typos	Flawless, targeted emails in the victim's language
Generic scams	Hyper-personalized using OSINT
Voice call "it's me"	Cloned CEO voice (LLM + TTS)
Static video	Deepfake video calls (rare but real)

The voice clone attack: 3-10 minutes of a person's voice online is enough to clone. CEO voice calls CFO: "transfer \$200k to vendor, I'll confirm by text." The CFO's "verify the number" check fails – the caller ID shows the CEO's number.

The Nuclear Verification

For ANY decision that matters:

Reverse call – hang up, call the known-verified number

Out-of-band check – text/IM the person through a channel the attacker doesn't control

Codeword – family/business agreed secret phrase

Verify the reason – why NOW? why THROUGH THIS channel? why ME?

OSINT in Social Engineering

Attackers gather (public) info before calling you:

LinkedIn → role, org, colleagues

Schedules/posts → where you are, business trips

Breach dumps → reused passwords, personal details

Your LinkedIn post "On vacation in Dubai next week" + a cloned co-worker voice = a top-tier spearphish a day later.

The meta-defense: treat anything *unexpected* that asks you to act as untrusted until verified. Surprises are the attack window.

[← Phishing: Anatomy & Detection](#)

Module complete ✓